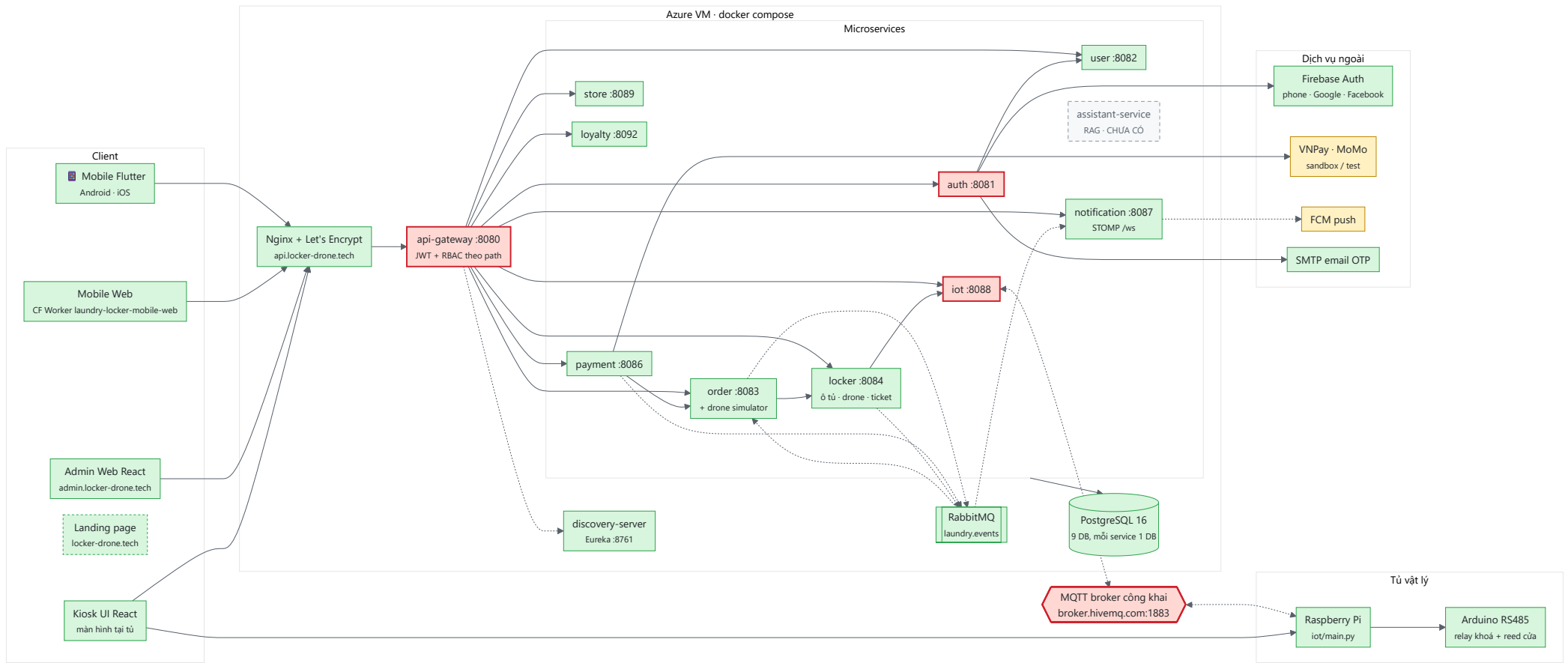


Kiến trúc hệ thống Lock.R

Nguồn: backend/pom.xml · api-gateway/.../application.yml · docker-compose.yml · .github/workflows/* · iot/main.py — rà soát code 2026-09-13

■ Đang chạy production
■ Sandbox / test / chưa kích hoạt
■ Rủi ro bảo mật
■ Cần có — CHỨA code (Luồng 4 RAG)
— HTTP/Feign
--- bất đồng bộ (RabbitMQ / MQTT / push)



- RỦI RO NGHIÊM TRỌNG:** (1) APP_SECURITY_JWT_SECRET production là giá trị mặc định hardcoded trong docker-compose.yml:66, 120 ⇒ ai biết chuỗi này giả được token ADMIN. (2) PUT /api/users/{id} nhận roles từ mọi người dùng ⇒ tự nâng quyền ADMIN. (3) iot-service nối broker MQTT công khai broker.hivemq.com:1883, không xác thực/TLS ⇒ ai cũng gửi được lệnh mở tủ.
- RabbitMQ exchange laundry.events: chỉ 2 hàng đợi có consumer (order.payment.events, notification.events). FCM push không bao giờ gửi (notification-service không khởi tạo Firebase). Pi thật không hiểu payload lệnh mở tủ của backend — hiện chỉ simulate_demo_cabinet.py chạy được end-to-end.